

Privacy Policy Red Flag Report

Platform: GROWW – Independent Privacy & Compliance Study

This report is an independent academic and policy analysis based on publicly available privacy policy language. It does not constitute legal advice or a formal determination of non-compliance. All findings are based on practical privacy-governance analysis with reference to the Digital Personal Data Protection Act, 2023 (India) and globally recognised privacy standards.

Overview:

Groww is one of India's largest online stock brokerage and investment platforms, offering services related to stock trading, mutual funds, digital investments, and financial management to millions of users across the country. As part of my independent privacy and compliance study, I conducted a detailed review of Groww's Privacy Policy – general, to understand how a major fintech platform handles user consent, personal data collection, profiling practices, third-party sharing, and transparency mechanisms from a data protection perspective.

Methodology:

The review involved a close reading of every clause in the public-facing policy, applying a structured red-flag methodology that assesses: (1) legal basis and quality of consent, (2) purpose limitation and data minimisation, (3) third-party and intra-group sharing disclosures, (4) user rights and control mechanisms, and (5) accountability and security practices. Each finding is mapped to a relevant DPDPA provision.

Areas of Concern Identified:

The observations primarily relate to:

- bundled and implied consent structures,
- broad third-party and affiliate data sharing,
- behavioural profiling practices,
- transparency limitations,
- accountability and security disclaimers.

Key Red Flags Identified:

1. Implied and Bundled Consent Through Platform Usage:

Policy Language: *“By accessing the Platform and/or using the Services, you accept and agree to be bound by the terms and conditions of this Privacy Policy.”*

The policy repeatedly states that by assessing the platform and/or using the services, or creating an account, users automatically signify acceptance of extensive data-processing activities.

Concern: The policy relies heavily on implied consent structures rather than granular consent. Under section 6 of DPDPA, 2023, valid consent must be free, specific, informed, and unambiguous and withdrawable. Consent is one of the legal bases to process personal data. Valid consent implies that the data principal clearly understands the nature, purpose and consequences of processing his/her personal data.

Recommendation: Implement granular consent options, allowing users to separately manage and withdraw consent for operations, marketing, profiling, and third-party sharing anytime.

2. Broad Affiliate and Group-Company Data Sharing:

Policy Language: *“Further, you hereby acknowledge and agree that our affiliates or group or subsidiary companies registered with financial services regulators may retrieve from your records available with third party.”*

The policy authorizes sharing of user data with group companies, affiliates, subsidiaries, and associated entities, without clearly defining exact purpose for each category of sharing data.

Concern: The disclosures are broad and may enable extensive intra-group processing without sufficient transparency.

Recommendation: Publish a clear affiliate data-sharing matrix and separately list each affiliate/subsidiary, the categories of data shared, and the specific purpose for each entity.

3. Extensive Third-Party Sharing Through Blanket Consent Language:

The policy repeatedly uses wording such as you hereby consent, you expressly agree or you provide your consent, while authorizing, data sharing, storage, transfer, processing with multiple third-party entities.

Concern: The policy does not clearly explain:

- how consent is obtained,
- whether users can separately control different processing activities,
- whether non-essential sharing can be declined.

Recommendation: Avoid using pre-ticked or declaratory consent clauses as it doesn't fall under the DPDPA standard for informed consent. Replace blanket language with a third-party disclosure and an opt-out path for non-essential sharing.

4. Automatic Behavioural Tracking and Profiling:

Policy Language: *"We may automatically track certain information about You based upon Your behaviour on the Platform. We use this information to do internal research on Your demographics, interests, and behaviour to better understand, protect and serve You."*

The platform states that it may, automatically track user behavior, analyse demographics, monitor interests, and conduct internal behavioural research.

Concern: The policy authorizes broad profiling and analytics practices without clearly explaining, profiling methods, retention periods, user controls, extent of behavioural monitoring.

Recommendation: Disclose profiling methodology and data categories used. Provide an opt-out for non-operational profiling and state retention periods.

5. SMS Data Access for Profiling and Internal Analysis:

Policy language: *"Your SMS data with third parties such as Banks, NBFCs, Billers/Utility Service providers etc towards the services offered and You hereby give Your consent for the same."*

The policy authorizes access to SMS-related data for profile building, internal evaluation, analysis.

Concern: SMS data may reveal highly sensitive financial and behavioural information. Such as, SMS data for a fintech user can reveal bank balances, OTPs, credit card activity, loan details,

and health expenditure. The policy relies on broad deemed-consent language without clearly demonstrating, granular permission mechanisms.

Recommendation: Trigger a separate, plain-language permission at the point of SMS access; clearly state what data is read, for what specific purpose, and how long it is retained. Provide an in-app mechanism to revoke this permission independently.

6. Broad Personalized Messaging and Profiling Activities:

Policy language: *“We use the Personal Information, Non-Personal Information, Transactional Information and User Communications and such other information provided by You for the following: - (xi) to allow Our business partners and/or associates to present customised messages to You.”*

The platform states that personal information, non-personal information, transactional information, user communications, and related user data may be utilized to enable business partners, associates, and affiliated entities to deliver customized communications and personalized messaging to users.

Concern: The policy does not clearly explain profiling logic, categories of partners involved, extent of data sharing, opt-out mechanisms.

Recommendation: Separate marketing-profiling consent from operational consent at signup; list partner categories in the policy; and place a clearly accessible 'Manage marketing preferences' option in the user dashboard.

7. Broad Third-Party Consultant Disclosure Framework:

Policy language: *“We may also disclose Your Personal Information including transactional information, to third party vendors, consultants, and other service providers of the Company, who are bound by contractual obligations to keep such personal information confidential and use it only for the purposes for which We disclose it to them and You hereby give Your consent for the same.”*

The platform may disclose personal and transaction-related information to third-party consultants.

Concern: A bare reference to 'confidentiality obligations' does not satisfy DPDPA Section 8(3), which requires that data processors act only on documented instructions and implement appropriate technical and organisational measures. Without detail, users and regulators cannot assess the adequacy of safeguards applied to consultant access.

Recommendation: Disclose the categories of consultants with access, the type of data each may access, the contractual obligations they are subject to, and the security standards, they must meet.

8. Broad Business Transfer and Restructuring Data Sharing:

Policy language: *“We and Our group companies, affiliates and subsidiary companies (to the extent Personal Information is collected by them) may, in compliance with applicable laws, share/transfer/assign all of Your Personal Information and other information with any other business entity(ies), in the event of a merger, sale, re-organization, amalgamation, joint ventures, assignment, restructuring of business or transfer or disposition of all or any portion of Our business.”*

The policy permits transfer of user data during mergers, acquisitions, restructuring, joint ventures, and business transfers.

Concern: No assurance is given that (a) users will be notified of a transfer, (b) the acquiring entity will be bound by equivalent privacy obligations, or (c) users will have any recourse if the new entity's practices are less protective. DPDPA Section 8 requires data fiduciaries to maintain accountability for processing even when engaging third parties.

Recommendation: Commit explicitly to notifying users before data transfer; require contractual privacy equivalence from acquiring entities; and offer users a deletion option before transfer takes effect.

9. Broad Third-Party Disclaimer and Limited Accountability:

Policy language: *“Our Platform may link You to other third – party Platforms (“Third – Party Sites”) that may collect Your Personal Information including Your IP address, browser specification, or operating system. The Company is not in any manner responsible for the security of such information or their privacy practices or content of those Third – Party Sites.”*

The policy states that third-party sites maintain independent privacy policies, and company is not liable for third-party information practices.

Concern: The company shifts most of the responsibility away from itself while still connecting users to third-party platforms and services without clearly explaining how user data is shared, tracked, or protected. Linking users to third-party platforms while disclaiming all responsibility creates an accountability gap. DPDPA holds the data fiduciary responsible for ensuring adequate protection whenever it facilitates data flows, even to independent third parties. A blanket liability waiver does not satisfy this obligation.

Recommendation: Before redirecting users to third-party platforms, display a clear notice of what data will be shared, conduct periodic privacy assessments of key partners, and maintain a mechanism for users to raise concerns about third-party practices.

10. Broad Security Disclaimer and Responsibility Shifting:

Policy language: *“We cannot however ensure or warrant the security of any information You transmit to the Company or guarantee that Your Personal Information and/or other Non-Personal Information provided for availing the Services or accessing the Platform will not be accessed, disclosed, altered or destroyed by a breach of any of Our security measures and safeguards.”*

The platform states that although security measures are implemented, it cannot ensure or warrant security of any information data principal transmit to the company. The company assumes no liability for unauthorized access or disclosure, and places substantial responsibility on users to maintain safeguards.

Concern: While no platform can guarantee absolute security, DPDPA Section 8(5) requires data fiduciaries to implement 'reasonable security safeguards' and establishes organisational accountability for breaches. A policy that places 'substantial responsibility' on users to maintain safeguards undercuts this statutory duty and may mislead users about their rights in the event of a breach.

Recommendation: State the security frameworks and standards applied (e.g. encryption at rest and in transit, access controls, audit logs); commit to breach notification timelines consistent

with DPDPA requirements; and remove language that places primary security responsibility on the user.

11. Repetitive Use of Deemed Consent Architecture:

Across multiple sections, the platform repeatedly states that users “hereby consent”, “expressly agree” and “signify acceptance”, without clearly demonstrating separate permission structures and revocation mechanisms.

Concern: This creates a recurring pattern of bundled and declaratory consent practices that may weaken meaningful user understanding and autonomy over sensitive processing activities. DPDPA requires that consent be withdrawable as easily as it is given (Section 6(4)); a policy-level declaration satisfies neither the spirit nor the letter of this requirement.

Recommendation: Conduct a full consent architecture review; replace declaratory clauses with in-product consent flows; implement a unified 'Privacy Dashboard' where users can view, manage, and withdraw each category of consent independently and in real time.

Final Observation:

The main concern observed throughout the privacy policy is that it repeatedly relies on implied consent, broad permissions, and extensive data-sharing clauses without giving users enough clear and separate choices. In many places, the policy assumes that users have already agreed to profiling, tracking, and third-party sharing simply by using the platform. While some data processing activities may be necessary for a fintech platform to operate smoothly, the policy would be more user-friendly and transparent if it provided clearer explanations, more specific purposes for data collection, better consent options, and stronger user control over optional activities such as profiling, personalized marketing, and third-party data sharing.